

SQL injection vulnerabilities in multiple vector stores in run-llama/llama_index

✓ Valid

Reported on Feb 28th 2025

Description

Multiple vector store integrations have SQL injection vulnerabilities, which can allow an attacker to read and write data using SQL.

Example vulnerable code snippet in the Couchbase vector store integration:

```
def delete(self, ref_doc_id: str, **kwargs: Any) -> None:
    """
    Delete a document by its reference document ID.

    Args:
        ref_doc_id: The reference document ID to be deleted.

    Returns:
        None
    """
    try:
        document_field = self._metadata_key + ".ref_doc_id"
        self._scope.query(
            f"DELETE FROM `{self._collection_name}` WHERE {document_field} = '{ref_doc_id}'"
        ).execute()
        logger.debug(f"Deleted document {ref_doc_id}")
    except Exception:
        logger.error(f"Error deleting document {ref_doc_id}")
        raise
```

Proof of Concept

Set up the Couchbase integration as described in this notebook: https://github.com/run-llama/llama_index/blob/main/docs/docs/examples/vector_stores/CouchbaseVectorStoreDemo.ipynb

Then, perform the SQL injection by running the following at the end of the notebook:

```
vector_store.delete("' OR '1'='1")
```

This will delete all data from the vector store.

Impact

This vulnerability can allow an attacker to read any data and write data from / to the vector store using SQL. This could e.g. lead to a user accessing data of other users, depending on how the llama-index library is used in a web application.

Occurrences



base.py L136



base.py L494-L503



base.py L333-L347



base.py L228-L230



base.py L334-L339

References

- [CWE-89: Improper Neutralization of Special Elements used in an SQL Command \('SQL Injection'\)](#)



We are processing your report and will contact the **run-llama/llama_index** team within 24 hours. a year ago



A **GitHub Issue** asking the maintainers to create a `SECURITY.md` exists a year ago



Massimiliano Pippi commented a year ago

Can we break down this report? Those are all different packages and I believe some of them are not worth it a fix, we might just discontinue some



A **run-llama/llama_index** maintainer has acknowledged this report a year ago



The scheduled publication date was automatically extended from 29th May 2025 to 5th Jun 2025 due to the maintainers acknowledgement of the report a year ago



Elias Hohl commented a year ago

Researcher

Hi Massimiliano, the way the bounties work is that the disclosure bounty (\$1500) is awarded on validation, and the additional bounty based on occurrences is awarded once you submit the fix, based on how many occurrences you actually fixed. So if you consider some occurrences not worth to fix, you can just leave them unfixed, the Huntr system will detect it, and reduce the bounty accordingly. Please just fix all the issues that you plan to fix in one commit, (or I think squashing commits upon merge into master branch also works), because currently the Huntr system allows only one fix commit to be submitted, if you fix it

in separate commits I will not be credited for all occurrences, as it happened to me before in another repository.



Massimiliano Pippi commented a year ago

Hey Elias thanks for the extra context. Being a monorepo, I can technically go with a single commit but that would correspond to multiple package releases with different versions. In other words, I can't come up with a single version number for the fix. Any suggestions about how to roll this out?



Elias Hohl commented a year ago

Researcher

Ah I understand the problem now. I think in terms of Huntr, I am quite sure that the bounty allocation would work out if you put it in one commit regardless of version numbers. If you need to specify a version, you could just specify the tag of the monorepo:
https://github.com/run-llama/llama_index/tags

Or would you like to get assigned a different CVE for each of the different packages? I guess this is possible too, but we would need to discuss with the Huntr team, because currently the UI prevents to have multiple vulnerability reports of the same type open in the same repo, so we would need to do it one-by-one, and the resulting bounty would be $18 \times 1500 = \$27k$ if I computed correctly, if every occurrence is submitted separately. I would gladly take it, but I doubt that the Huntr team would pay this :)



Massimiliano Pippi commented a year ago

I see, good point indeed! Ok I'll roll out the fixes in one commit and in the version tag for the resolution I can probably put the one from the `llama_index` umbrella package, I think it's accurate enough. I didn't go through all the modules in the report but I sampled a couple and they're valid, so I'm validating the report, thank you!



Massimiliano Pippi validated this vulnerability a year ago

\$ **ehtec** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7



CVE-2025-1793 assigned to this report. a year ago



Elias Hohl commented a year ago

Researcher

Thank you very much for the quick validation. In case you haven't seen, please also check the 3rd vulnerability I submitted, and some more might come today / tomorrow



Massimiliano Pippi commented 10 months ago



✓ Massimiliano Pippi marked this as fixed in **0.12.28** with commit **000804** 10 months ago

\$ Massimiliano Pippi has been awarded the fix bounty ✓

\$ base.py#L334-L339 has been validated ✓

\$ base.py#L494-L503 has been validated ✓

\$ base.py#L333-L347 has been validated ✓

\$ base.py#L136 has been validated ✓

\$ base.py#L228-L230 has been validated ✓

✉ We have notified the **run-llama/llama_index** maintainers about this report in their weekly follow-up 8 months ago

⚠ We have sent a warning to the **run-llama/llama_index** team to inform them that this report will be published in 48 hours 8 months ago

📡 This vulnerability has now been published 8 months ago

🔐 CVE-2025-1793 has now been published 8 months ago

Kunam Balaram Reddy commented 8 months ago

@Masci @ehtec Can i know the attack vector example. I dont see any direct user input triggering vector store methods like delete, except the developer who is writing the script. Thanks.



Elias Hohl commented 8 months ago

Researcher

llama_index is a library, if used by a web application, document IDs from a user could be passed to the vulnerable function, making SQL injection possible

Kunam Balaram Reddy commented 8 months ago

I got it. but politely, i am not convinced until i see a possible poc.

Kunam Balaram Reddy commented 8 months ago

according to usage of lamaindex, vector store is used by the script writers not the users.

Kunam Balaram Reddy commented 8 months ago

May be i am thinking wrong or differently now.

[Sign in](#) to join this conversation

CVE

CVE-2025-1793

Published

Vulnerability Type

CWE-89: SQL Injection

Severity

Critical (9.8)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	High
Integrity	High
Availability	High

[Open in visual CVSS calculator](#) 

Registry

Other

Affected Version

v0.12.21

Visibility

Public

Status

Fixed

Disclosure Bounty

\$3000

Fix Bounty

\$375

Found by



Elias Hohl

@ehtec

MIDDLEWEIGHT



Fixed by



Massimiliano Pippi

@masci

UNPROVEN



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)